

Python Secure Coding Guide

Input Validation: Validate and sanitize all user input.

Secrets: Use environment variables or secret managers.

Dangerous Functions: Avoid `eval()`, `exec()`, `pickle` on untrusted input.

SQL: Use parameterized queries.

Dependencies: Pin and update packages.

Authentication: Hash passwords with `bcrypt`/`argon2`.

Logging: Avoid logging secrets.

File Handling: Validate file types and paths.